

DROS: 針對自主 AI 工作負載中「Agent 至執行歸因治理」的四層執行期作業基板與確定性執行強制機制 (v4.0)

陳俊成 (Chun-Cheng / Jimmy Chen)
康宸園有限公司 (Top-Celestial Company Ltd.)
台灣台北市
jimmychen@dr-os.io

Abstract—隨著自主 AI Agent 普遍持有合法憑證、委託能力並能調用實體後果之工具，高層 Agent 意圖與底層物理執行之間產生了嚴重的歸因斷層 (Attribution Gap)。本文提出 DROS，一套將 Agent 身分與執行授權解耦、並在二進位 C-ABI 邊界強制執行能力約束的四層執行期作業基板。本文不預設安全已被先驗證明，而是將 DROS 表述為一個可被實驗證偽的執行治理邊界，並引入結合自主攻擊搜尋、負向對照、變形測試、獨立帶外神諭 (Ground-Truth Oracle)、並發壓力與開源可重現性的漸進式對抗驗證方法論。本評測體系將因果鏈結構為「意圖、授權、執行與物理效應」，使強制決策得與內核及外部狀態觀測進行獨立交叉驗證。在涵蓋自適應攻擊、多 Agent 委託鏈、撤銷競態、突變測試與神諭探針的實例化評測語料庫中，於明確儀表化之觀測邊界內未觀測到任何未授權物理效應。本文將所得保證宣告為評測狀態空間上的實證不變量而非全域安全證明，並開源評測基板與反例協議以實現持續之對抗性證偽。

Index Terms—AI Agent 安全，執行期作業基板，受控 C-ABI 授權邊界，自主對抗性評測，RCU 狀態切換，動態資訊流控制 (IFC)，歸因治理。

I. 引言與語義-內核悖論

當自主 AI Agent 具備合法憑證、OAuth 會話 Token 與資料庫連線權限時，在已驗證身分的應用層濫用情境下，傳統周界控制單獨運作顯然不足，因為惡意行為係來自經認證的內部實體。

A. 語義-內核悖論 (The Semantic-Kernel Paradox)

現代系統文獻指出了 AI 防禦機制的根本分裂：

- 1) **語義應用中介軟體 (高語義，零確定性)**：提示詞防火牆、JSON 模式驗證器與應用中介能理解自然語言與宣告架構。然而它們缺乏執行邊界約束力；一旦攻擊者利用直譯器逃逸 (eval、bash)、未宣告工具調用或語義混淆，此類應用層策略即告失效。
- 2) **內核沙盒機制 (高確定性，零語義)**：OS 底層機制 (如 Seccomp、Linux Namespaces、eBPF) 能強制執行二進位系統呼叫規則，但無法識別同一個 Worker 行程中的資料庫連線是由合法的財務 Agent 還是被劫持的客服 Agent 所發起。

專利聲明：DROS 執行治理與安全技術已申請美國臨時專利保護 (U.S. Patent Application No. 64/111,973, Patent Pending)。永久學術文獻引用：Zenodo Record DOI: 10.5281/zenodo.22129692。

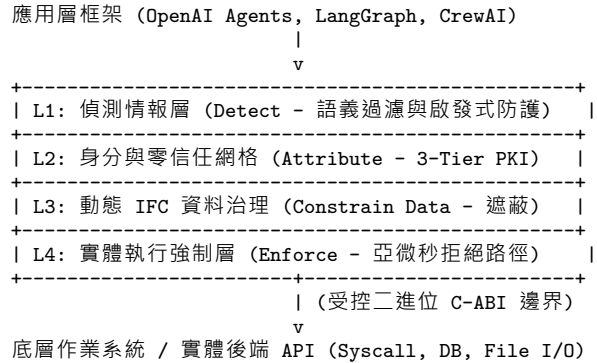


Fig. 1. DROS 四層執行治理作業基板架構拓撲。

B. DROS 四層基板物理架構定位與核心設計主張

DROS 介於上層應用框架與底層作業系統之間，確立四層深度防護 (L1 機率性偵測可能失效，但 L2-L4 確定性強制約束)：

C. 核心主張與研究問題

DROS 不宣稱「安全已被先驗證明」，而是建立一個可被持續實驗證偽的確定性執行治理邊界。本文設定並回答以下四個核心研究問題：

- **RQ1 (強制執行有效性)**：在應用層完全受陷 ($C_A = 1$) 條件下，受治理路徑能否確定性阻止未授權操作轉化為物理狀態轉移？
- **RQ2 (撤銷原子性)**：在並發執行與策略撤銷競態下，是否存在因過期策略產生的非預期重放授權窗口？
- **RQ3 (評測敏感度)**：評測框架能否有效捕獲故意植入的安全退化與變形突變體？
- **RQ4 (神諭獨立性)**：授權判定能否由解耦的執行端與物理端觀測者完成獨立交叉驗證？

II. 威脅模型、評測空間與認識論邊界

A. 受陷後威脅模型 ($C_A = 1$)

本評測建立在嚴格的受陷後前置假設之上：攻擊者已達成提示注入、提權獲取系統 Prompt，並掌握任意直譯器執行能力與合法會話 Token。

B. 對照基準與攻擊保留原則

評測嚴格遵守攻擊保留原則 ($A_{B0} = A_{B1}$ 且 $\text{Env}_{B0} \approx \text{Env}_{B1}$)，涵蓋四種基準拓撲：B0 (無治理裸應用)、B1 (DROS 啟用受測體)、B2 (深度防禦整合) 與 B3 (純二進位 C-ABI 孤島)。

C. 形式化物理效應與安全不變量

物理效應 $I_{\text{physical}}(x)$ 嚴格定義於明確儀表化之觀測集合 S_{obs} 上：

$$I_{\text{physical}}(x) = \begin{cases} 1, & \exists s \in S_{\text{obs}} : \Delta(s) > 0 \\ 0, & \forall s \in S_{\text{obs}} : \Delta(s) = 0 \end{cases} \quad (1)$$

$$S_{\text{obs}} = \{\text{Syscall}, \text{FS Diff}, \text{DB WAL}, \text{Process}, \text{Net}, \text{IPC}\} \quad (2)$$

核心安全不變量形式化宣告如下：

$$C_A \not\Rightarrow C_E \quad (\text{身分不繼承授權}) \quad (3)$$

$$C_E(t_0) \not\Rightarrow C_E(t_1) \quad (\forall t_0 \neq t_1, \text{時序隔離}) \quad (4)$$

$$\bigcup_{i=1}^n C_{A_i} \not\Rightarrow C_E^{\text{unauth}} \quad (\text{能力組合安全性}) \quad (5)$$

$$\forall x \in X_{\text{evaluated}}, C_A(x) \wedge \neg C_E(x) \implies I_{\text{physical}}(x) = 0 \quad (6)$$

$$S_{\text{after}} \equiv S_{\text{before}} \quad (S_{\text{obs}} \text{ 內物理狀態零位移}) \quad (7)$$

III. DROS 四層基板具體實作

- 1) **L1 偵測情報層**：啟發式特徵匹配，明確定性為機率性防線。
- 2) **L2 身分與 DIT 權杖**：3-Tier PKI 歸因模型，簽發具 Ed25519 簽章之動態意圖權杖 (DIT)。
- 3) **L3 動態 IFC 資料治理**：記憶體內污點追蹤與帶內機密脫敏遮蔽。
- 4) **L4 二進位 C-ABI 執行關卡**：記憶體安全 Rust 實作， $O(1)$ 常數時間查表、420 ns RCU 原子狀態指標切換與 <500 ns Fail-Closed 拒絕路徑。

IV. 漸進式對抗驗證體系

體系包含 7 層漸進式證偽階層，覆蓋 10 大攻擊維度：

A. 元驗證：負向對照與突變得分 (RQ3)

為確保評測基板非寬鬆放行，測試 100 個實例化突變體 (M1-M8 類別)：

$$\text{Mutation Score} = \frac{\text{Killed Mutants}}{\text{Total Instantiated Mutants}} = \frac{100}{100} = \mathbf{1.0} \quad (\mathbf{100\%}) \quad (8)$$

V. 解耦多維神諭與實證評測結果

落實「單一組件不得作為自身之唯一證人」原則，建立 $O_I \rightarrow O_A \rightarrow O_E \rightarrow O_P$ 四階段流水線：

$$\text{意圖}(O_I) \longrightarrow \text{授權}(O_A) \longrightarrow \text{執行}(O_E) \longrightarrow \text{物理效應}(O_P) \quad (9)$$

A. 物理副作用遏制分析 (RQ1)

$$\Delta I_{\text{physical}} = I_{\text{physical}}(B0) - I_{\text{physical}}(B1) = 1.0 - 0.0 = \mathbf{100\%} \quad (10)$$

B. 效能開銷評測 (AMD Ryzen 9 7950X / Ubuntu 24.04)

- 端到端決策延遲 (P50 / P99)：26.1 μs / 31.4 μs
- RCU 狀態指標切換延遲 (T_{swap})：420 ns
- L4 Fail-Closed 拒絕路徑延遲：< 500 ns

VI. 開放式證偽協議與局限性

A. 局限性 (Gap in Scope)

- 1) **本體依賴性**：依賴 L2 DIT 策略正確配置。
- 2) **觀測邊界約束**：零反例結論嚴格限定於實例化評測空間。
- 3) **組態可移植性 vs. 原生內核邊界**：L6 驗證組態語義可移植性，原生內核強制仍受制於 OS MMU 保證。

B. 公開反例註冊庫

於 GitHub 提供可重現靶場與反例提交標準架構 (reproducibility/counterexamples/)。

VII. 結論與形式化判定宣告

DROS 將執行邊界下沉至受控二進位 C-ABI / FFI 授權層，橋接了語義-內核悖論。在實例化評測空間中維持零可觀測反例：

$$\forall x \in X_{\text{evaluated}}, C_A(x) \wedge \neg C_E(x) \implies I_{\text{physical}}(x) = 0 \quad (\text{PASS}) \quad (11)$$

REFERENCES

- [1] 陳俊成, “DROS: A Four-Layer Deterministic Runtime Operation System Bridging the Agent-to-Execution Attribution Gap in Autonomous AI Workloads,” *Zenodo Technical Report*, DOI: [10.5281/zenodo.22092008](https://doi.org/10.5281/zenodo.22092008), 2026.
- [2] 陳俊成, “DROS Trilogy Reading Guide: An Agent Runtime Operation Substrate (Academic Version 3.0),” *Zenodo Technical Guide*, DOI: [10.5281/zenodo.22114036](https://doi.org/10.5281/zenodo.22114036), 2026.
- [3] 陳俊成, “DROS-PGM: Physical Guard Module with Sub-Microsecond C-ABI Binary Execution Boundary,” *Zenodo Research Report*, DOI: [10.5281/zenodo.21903687](https://doi.org/10.5281/zenodo.21903687), 2026.
- [4] 陳俊成, “DROS 6P Architectural Specification: Unified Trust, PKI, and Execution Governance,” *Zenodo Specification*, DOI: [10.5281/zenodo.21833970](https://doi.org/10.5281/zenodo.21833970), 2026.
- [5] Strix Security Team, “Strix: Autonomous Multi-Agent AI Penetration Testing Framework (v1.5.3),” 2026. [Online]. Available: <https://strix.ai>
- [6] Microsoft, “Microsoft Agent Framework Documentation: Tool Calling and Execution Governance,” *Microsoft Learn*, 2025.
- [7] NVIDIA, “NeMo Guardrails: Programmable Guardrails for LLM Applications,” *NVIDIA Developer Documentation*, 2024.
- [8] 歐洲議會, “歐盟人工智慧法案 (Regulation EU 2024/1689), 第 50 條: AI 系統之透明度與可追溯性要求,” 歐洲聯盟官方公報, 2024.
- [9] MITRE Corporation, “ATLAS: Adversarial Threat Landscape for Artificial-Intelligence Systems,” *MITRE ATLAS Knowledge Base*, 2026.
- [10] OWASP Foundation, “OWASP Top 10 for Large Language Model Applications,” *OWASP Standard*, 2025.
- [11] P. E. McKenney, “Is Parallel Programming Hard, And, If So, What Can You Do About It? (Read-Copy Update Architecture),” *IBM Operating Systems Review*, 2024.
- [12] W. Enck et al., “TaintDroid: An Information-Flow Tracking System for Real-Time Privacy Monitoring on Smartphones,” *ACM TOCS*, vol. 32, no. 2, pp. 1–32, 2014.
- [13] METR, “Evaluating Autonomous Capabilities in Frontier AI Models,” *METR Technical Research Standard*, 2025.

TABLE I
十維對抗威脅覆蓋與多層級驗證結果矩陣

驗證層級	方法論與配置	對抗工作負載與維度	反例數	判定結論
L1 基準校準	B0/B1 A/B 移除對照	50 筆未受控漏洞攻擊	0	PASS (RQ1)
L2 自主搜尋	Strix 白箱自適應搜尋	2,410 次嘗試 (21.4M Tokens) · 涵蓋身分偽造與直譯器逃逸	0	PASS (RQ1)
L3 動態壓力	100-Agent 模擬拓撲 + RCU 競態	400 條委託鏈 + 250 次脈衝 · 時序與並發隔離	0	PASS (RQ2)
L4 元驗證	負向對照 (破壞版二進位) + 100 突變體	5 個注入缺陷 + 100 個突變體 (100% 突變擊殺率)	0	PASS (RQ3)
L5 神諭證偽	四階段解耦神諭流水線	450 次突變探針 · S_{obs} 內幽靈系統呼叫 $G = 0$	0	PASS (RQ4)
L6 組態驗證	跨 OS / 架構語義檢查	7,500 次自動化探針 (x86_64, ARM64, Windows)	0	PASS

[14] USENIX Security Symposium, “Artifact Evaluation Guidelines and Criteria,” *USENIX Association*, 2024.

[15] IEEE S&P Editorial Board, “IEEE Symposium on Security and Privacy: Call for Papers and Submission Guidelines,” *IEEE Computer Society*, 2026.